IT UNIVERSITY OF COPENHAGEN

# Final Report

Master of Science in Computer Science
IT-University of Copenhagen

**Course Name:** DevOps: Software Evolution and Software Maintenance
**Course Code:** KSDSESM1KU
**Submission Date:** ??/??/2025


| **Author** | **Email** |
| --- | --- |
| Jacob Sonne | json@itu.dk |
| Renate Mekere | rmek@itu.dk |
| Adam Nørgård Aabye | aaab@itu.dk |
| change file name to `MSc_group_e.pdf` author5 | author4 |
| author6 | author5 |
| | author6 |

# Table of contents


1 Process' perspective . . . . . 1
1.1 CI/CD pipelines . . . . . 1
1.2 Monitoring . . . . . 2
1.3 Logging . . . . . 3
1.4 Security Hardening . . . . . 4
1.5 Availability and scaling . . . . . 7
2 System's Perspective . . . . . 7
2.1 Design and Architecture . . . . . 7
2.2 Dependencies . . . . . 10
2.3 Current System State . . . . . 12

# 1 Process' perspective

## 1.1 CI/CD pipelines

Our project mainly use two separate pipelines called "PR Quality Gate" and "CI/CD Pipeline Production Server". Both pipelines utilizes a pipeline template called "Merged Test Suite", which will be referred to as the "test-suite".

### PR Quality Gate pipeline

This pipeline functions as a quality gate whenever we create a Pull Request (PR) into our development branch called "develop". Each time a PR is created or updated, the pipeline would run some static analysis checks, build the solution, and test if our test-suite passes. An overview of the pipeline can be seen in figure 1. Additionally SonarQube and Codacy has been set up for the git repository such that every time a Pull Request is created it will scan the code.

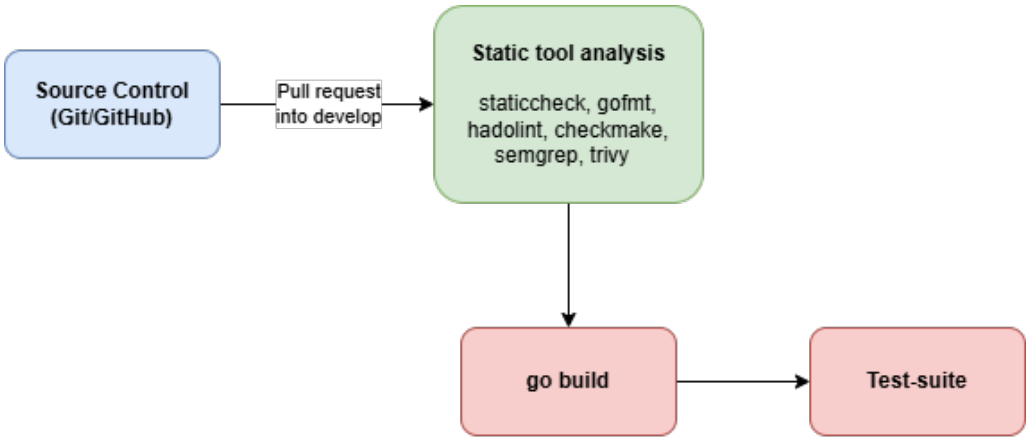



**Figure** 1: Overview of the PR Quality gate pipeline

### CI/CD Pipeline Production Server pipeline

This pipeline also runs the quality checks as the "PR Quality Gate" pipeline, however after that it also pushes our docker images to a docker registry and deploys our

application in our production environment. The pipeline is triggered each time an update is triggered on the main branch. It only deploys if every prior step succeeds.An overview of this pipeline can be seen in figure 2.

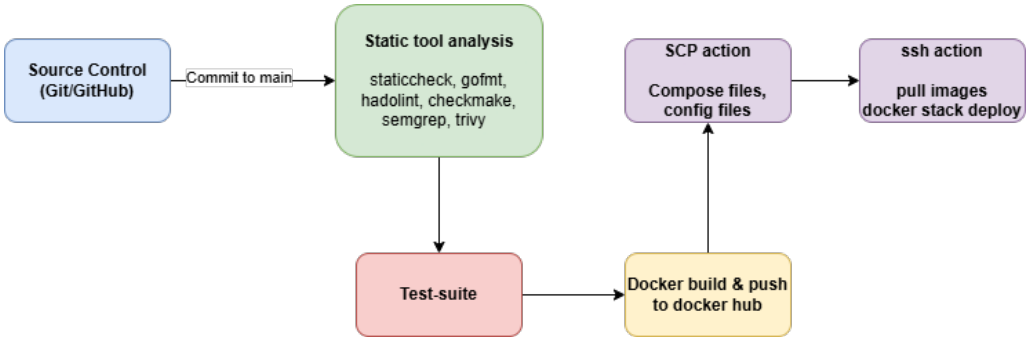



**Figure** 2: Overview of the CI/CD pipeline

### Test-suite

The test suite is a template pipeline that is responsible for testing that the applications passes UI tests, unit tests and API tests. An overview of the pipeline template can be seen in figure 3.

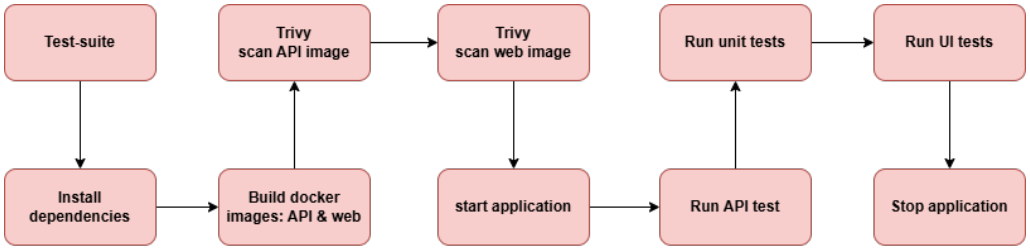



**Figure** 3: Illustration of the test-suite's steps and tools

## 1.2 Monitoring

For monitoring, we use a combination of Prometheus, cAdvisor, Node Exporter, and Grafana. Prometheus acts as the central metrics collection and storage system and it periodically scrapes metrics from the configured exporters and make them

available as a data source for Grafana. Node Exporter exposes host-level metrics from the nodes, such as CPU, memory, disk, and network usage, while cAdvisor exposes container-level metrics, such as per-service CPU core utilization broken down by Docker Swarm service name.

Grafana is used as the data visualization layer and we have configured two dashboards which can be seen in the appendix (section **??**):

- **Availability Dashboard**: Tracks the uptime of the Minitwit API, Minitwit Web, cAdvisor, and Node Exporter using Prometheus' `up` metric. It shows each service's availability percentage over time, as well as a state timeline indicating when services were up or down. The dashboard can be seen in the appendix or here .
- **Resource Usage Dashboard**: Provides a detailed view of the infrastructure health, including CPU utilization (min, mean, max, and p95), the memory utilization (total, used, and available), disk utilization, and network throughput (bytes received and transmitted) .

In addition to the dashboards, Grafana is configured with alert rules based on the `up` metric for both the Minitwit API and the Minitwit Web services. If either service becomes unavailable, an alert is triggered, and a notification is sent to the team via a Discord webhook, allowing us to quickly respond to unexpected downtime.

## 1.3 Logging

We use a Go library called "zerolog" for structured logging. We chose zerolog because it supports multiple log levels, is lightweight and performant, and is widely used in the Go community.

To collect the logs from the Docker containers running in the swarm, we use Promtail. Promtail adds metadata labels to each log entry before forwarding them, making it easier to search and filter logs later. In our case, Promtail adds the following labels:

- `app`: Whether the log originates from the web or API service.
- `endpoint`: The logical endpoint that was called, e.g. `register`, `msg`, or `fllws_username`.
- `method`: The HTTP method of the request, e.g. `GET` or `POST`.
- `statusCode`: The HTTP response code returned, e.g. `200` or `404`.
- `level`: The log level of the entry, e.g. `info` or `error`.

The logs are then forwarded to Loki, which is our log aggregation system. Loki indexes the labels created by Promtail, enabling fast and efficient querying without indexing the full log content.

Since Grafana was already used for the monitoring dashboards, we also use it to visualize the aggregated logs through an **API Dashboard** (see appendix **??**). The dashboard queries Loki and displays the following information:

- **Summary statistics**: Total requests, successful requests (info-level), errors, and overall error rate percentage across the selected time range.
- **Request time series**: A graph showing request volume per endpoint over time.
- **Per-endpoint breakdown**: A table showing total, successful and failed requests along with the error rate for each individual endpoint.
- **Raw log view**: A filterable view of raw log entries, supporting filtering by endpoint, HTTP method, and log level.

## 1.4 Security Hardening

A focused security assessment was conducted on the MiniTwit system to identify risks across infrastructure, CI/CD workflows, deployment configuration, and application behavior. The assessment was based on static analysis tools, manual inspection of workflows, firewall testing, and external port scanning.

The identified risks are summarized in Figure 4. The most critical risks were related to exposed network ports, insecure handling of secrets, and database instability under load.

| Risk | Likelihood | Impact | Priority |
|---|---|---|---|
| Exposed network ports | Likely | High | Critical |
| Secrets in environment variables | Likely | Critical | Critical |
| Root containers | Likely | Critical | Critical |
| Database connection exhaustion | Likely | Critical | Critical |
| Mutable Docker image tags | Possible | High | High |
| Public monitoring exposure | Possible | High | High |
| SSH brute-force risk | Possible | High | High |
| Unpinned GitHub Actions | Possible | High | High |
| Inherited secrets in workflows | Possible | High | High |

**Figure** 4: Overview of identified security risks categorized by likelihood and impact

### Implemented Improvements

The most significant improvement was firewall hardening on all three nodes using UFW. A deny-by-default incoming policy was configured, and unnecessary public ports were removed. Previously exposed ports included Docker management ports (2375, 2376, 2377) and direct application ports (5000, 5001). After hardening, only essential services remained publicly accessible:

- SSH (22)
- HTTP (80)
- HTTPS (443)
- Docker Swarm management (2377)
- Docker Swarm node communication (7946)

- Docker overlay network (4789)

All application traffic is now routed through the Nginx reverse proxy, reducing the system's public attack surface. Firewall changes were validated using external port scanning, confirming that removed services were no longer reachable.

To mitigate brute-force attacks, Fail2Ban was installed and configured to block repeated failed SSH login attempts. Automatic system updates were also enabled to ensure that known vulnerabilities are patched regularly.

Security scanning was integrated into the CI/CD pipeline using tools such as Semgrep and Trivy as well as having SonarQube and Codacy enabled for the repository. These tools help detect insecure code patterns and misconfigurations before deployment.

HTTPS is enabled using Let's Encrypt certificates managed via Certbot with Nginx configured to terminate TLS on port 443.

**Remaining Risks and Improvements**

Despite these improvements, some risks remain:

- Secrets are stored in environment variables and should be moved to a secure secret management solution
- Prometheus and Promtail run with elevated privileges (root user) in order to access the Docker socket and container logs respectively
- Docker images use mutable tags, reducing deployment reproducibility
- Monitoring tools may be publicly accessible
- Database connection limits caused instability under load

Future improvements include restricting monitoring access, using Docker Secrets, running containers as non-root users, introducing database connection pooling, and improving backup strategies.

Overall, the implemented measures significantly improved the security posture of the system, while highlighting areas for further hardening.

### 1.5 Availability and scaling

To achieve high Availability we use Docker Swarm with an on-failure restart policy and a rolling update strategy. Docker Swarm allows us to have multiple replicas of our services. If one replica goes down, other replicas will still be up and running, meaning that we don't suffer downtime. The on-failure restart policy means that any replica which goes down, is rebooted automatically. The rolling update policy means that when we ship new features, the replicas are updated one at a time, which means we can achieve zero down time when making new releases.

Docker Swarm is also the answer to the question of scaling. By replicating our services we employ horizontal scaling, and with Swarm Mode also comes load balancing. This means that requests to our services are distributed among the nodes and containers to not overburden any single replica.

This once again means high availability since, if the worker dies the manager is still controlling the swarm and running containers, and if the manager dies, the worker node can still run existing containers though new deployments will be unavailable until the manager recovers The application infrastructure is described in detail in Section 2.1.

# 2 System's Perspective

## 2.1 Design and Architecture

The Minitwit system is deployed on DigitalOcean using three droplets: one PostgreSQL database node, one Docker Swarm manager node, and one Docker Swarm worker node. The application is containerized and deployed through Docker Swarm, which runs and manages the application services across the swarm.

The team have implemented a PowerShell-based deployment script, `scripts/deploy-existing.ps1`. The script deploys to already existing droplets by connecting to the

server with SSH, copying configuration files with SCP, setting the required environment variables, and deploying the services using Docker Swarm.

The public entry point to the system is Nginx. Incoming traffic is routed through Nginx, which forwards requests to the web service, the API service, or Grafana based on the URL path. The API and web services communicate with the PostgreSQL database for persistent storage. The simplified request flow is:

`Browser / Simulator` → `Nginx` → `Web / API` → `PostgreSQL`

The system also includes a full monitoring stack comprising Prometheus, Grafana, Loki, Promtail, cAdvisor, and node-exporter, which is described in detail in Section 1.2.

The deployment architecture is illustrated in Figure 5.

A `scripts/create-infrastructure.ps1` script was also implemented to automate full infrastructure creation from scratch. It creates the three droplets, installs PostgreSQL and Docker, configures Docker Swarm, joins the worker node, and restores the database from a backup. A companion script `scripts/backup-database.ps1` backs up the live PostgreSQL database before any redeployment. Testing of the full infrastructure creation was limited because the DigitalOcean account reached the three-droplet limit, preventing creation of new droplets while the existing ones were running.

Additionally two sequence diagrams were created to visualize the sequential flow of logging in and posting a message in the solution. The interaction can be seen in figure 6 and 7.

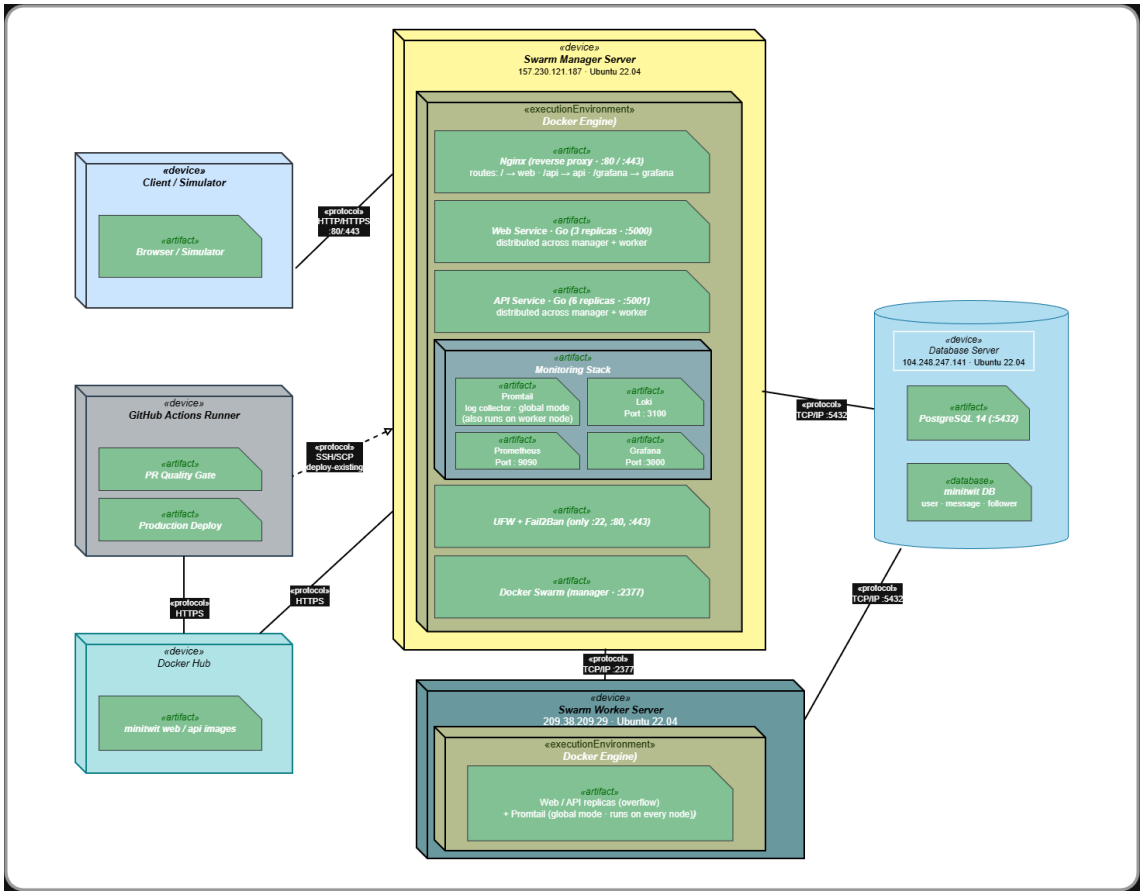



**Figure** 5: Deployment diagram of the MiniTwit system

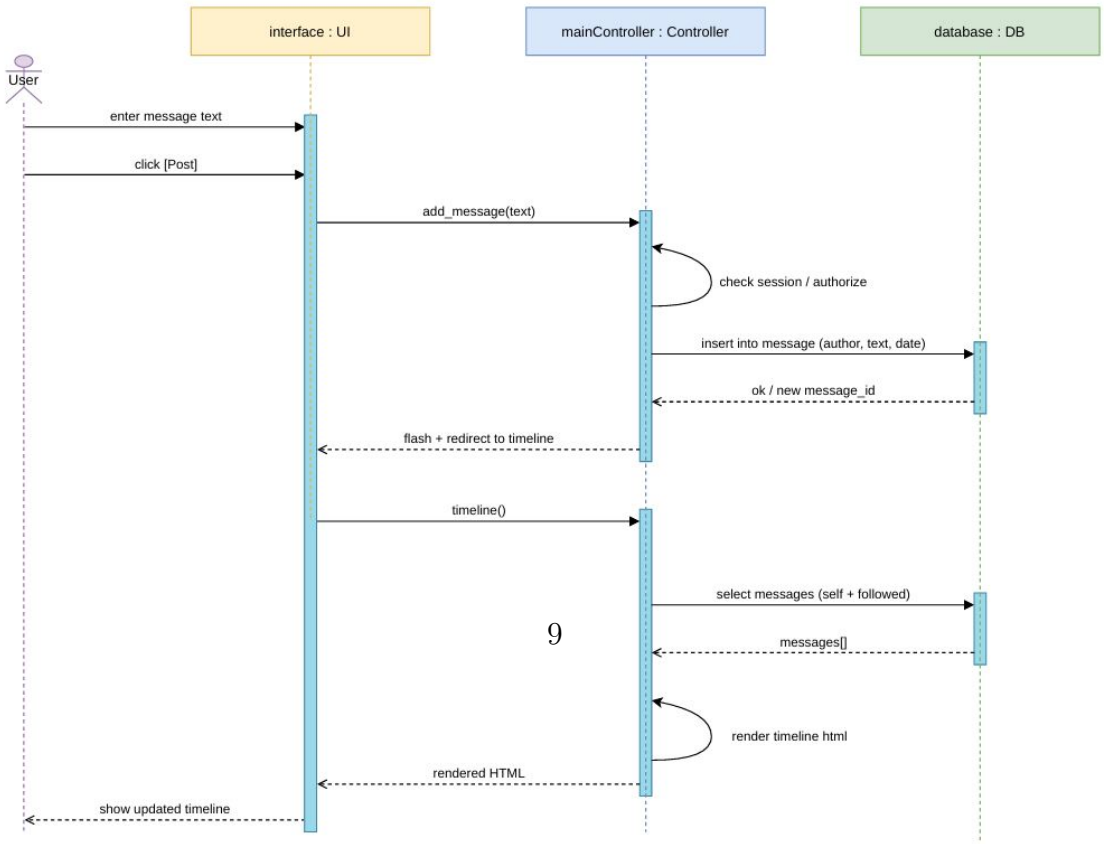





**Figure** 6: Post creation and timeline rendering sequence diagram

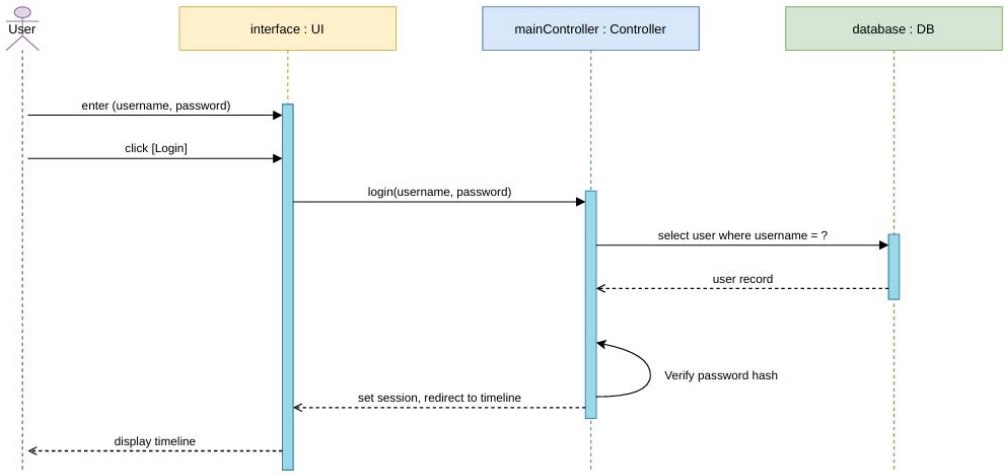



**Figure** 7: Login sequence diagram of the MiniTwit system

## 2.2 Dependencies

The following are the dependencies for our Minitwit system, listed in an organized manner in order to better provide an overview.

### Runtime Dependencies

These dependencies include the environment to run the application on including the operating system, VM technologies and programming language.

- Ubuntu Linux: Operating System
- Docker (swarm mode): Virtual Machine
- golang:1.25 (Docker image)

### Application Libraries

This list contains the libraries and what each library is for.

- Go 1.25.6: Programming language.
- Gorilla Mux: HTTP request routing.
- Gorilla Sessions: Session management.
- GORM: Object-relational mapper.
- PostgreSQL Driver: Database connectivity.
- Zerolog: Structured logging.
- Prometheus client_golang: Metrics instrumentation.

### Testing

- Python 3.11: Programming language
- pytest: Testing framework

### DevOps / Build Dependencies

This list includes tools for employing DevOps practices.

- Github: Code repository
- Dockerhub: Docker image repository
- Github Actions: CI/CD Pipeline
- Codacy: Quality assurance
- SonarQube: Quality assurance
- Trivy: Pipeline hardening
- Fail2Ban: Intrusion-prevention framework

## 2.3 Current System State

The application has certain issues, which have not been resolved due to lack of time. These issues are mentioned below.

- Ideally we would have more nodes, and more managers to ensure that even if a manager dies, another manager can still remain in control of the swarm.
- There is a bug where it is possible to create multiple instances of the same user.
- There are currently no logging for the WEB part of the application. This has been neglected as almost all traffic has come from the simulator, which only talks with the API.
- Our entire monitoring stack as well as nginx don't have a health check configured, meaning we cannot monitor the uptime of these services
- We have used Trivy for analysing dependencies in in the docker images, but have not acted on the information.